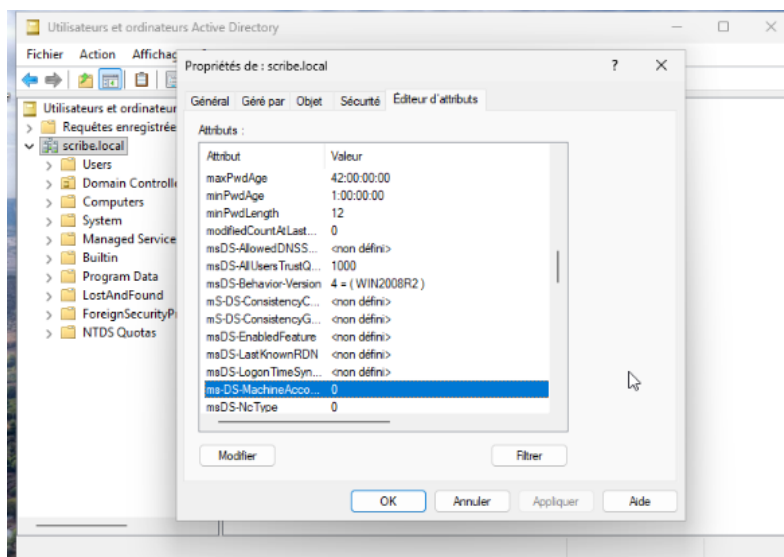


REMÉDIATION : SÉCURISATION DE L'ANNUAIRE SCRIBE.LOCAL

1. Passer le Quota de machines (MAQ) à 0 (dsa.msc)

C'est le point bloquant de tout à l'heure. C'est crucial pour supprimer l'indicateur d'exposition Purple Knight sur le ms-DS-MachineAccountQuota.

1. Sur le Windows 11, ouvre **Utilisateurs et ordinateurs Active Directory** (dsa.msc).
2. Va dans le menu **Affichage** et coche **Fonctionnalités avancées**.
3. Fais un clic droit sur ton domaine scribe.local (tout en haut de l'arborescence) et choisis **Propriétés**.
4. Va sur l'onglet **Éditeur d'attributs**.
5. Cherche la ligne ms-DS-MachineAccountQuota.
6. Double-clique dessus, remplace **10** par **0**, et valide.

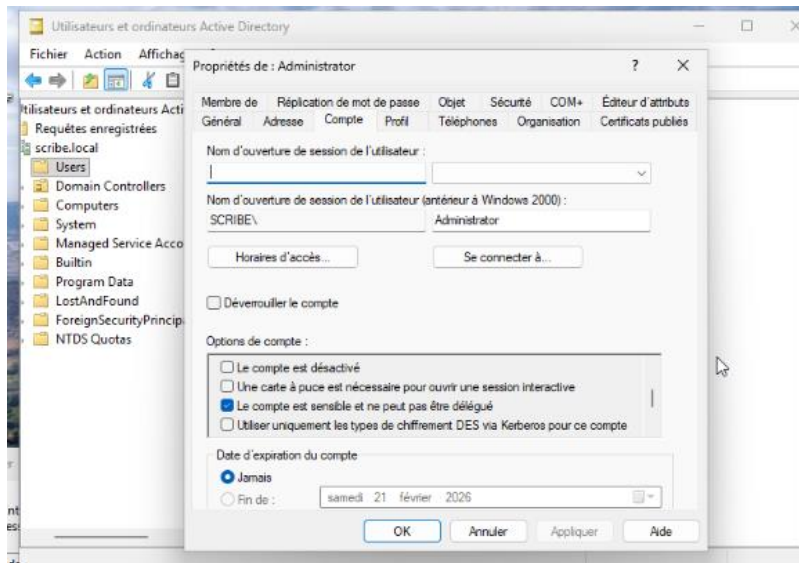


2. Protéger les administrateurs (Sensitive Flag)

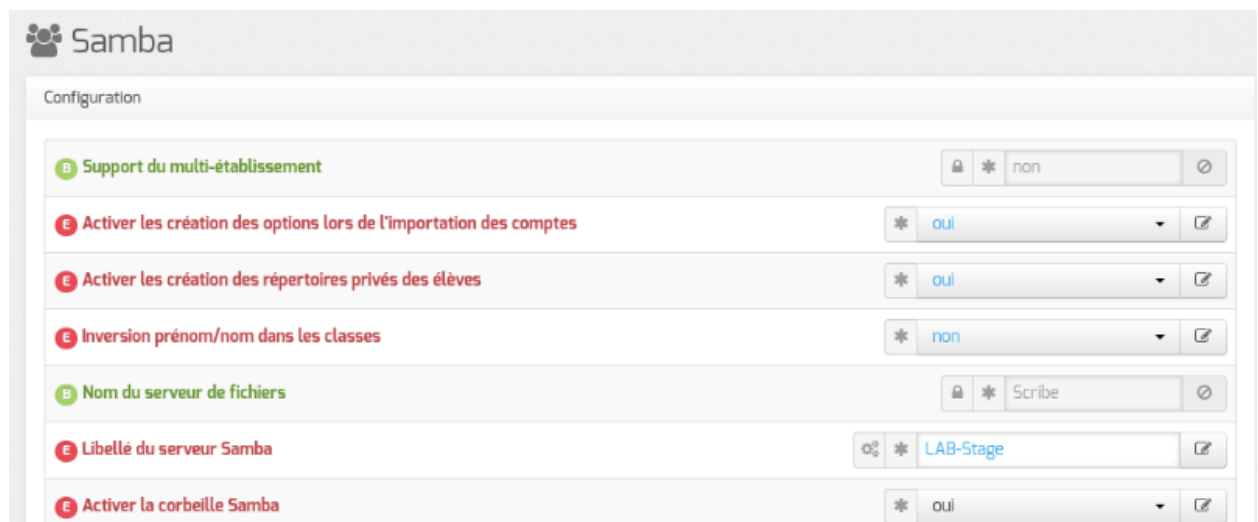
Pour faire chuter le score de risque des comptes privilégiés dans PingCastle, je dois activer cette option sur mes 4 admins identifiés.

1. Toujours dans dsa.msc, va dans le dossier **Users**.
2. Fais un clic droit sur le compte Administrator -> **Propriétés**.
3. Va sur l'onglet **Compte**.
4. Dans la liste des "Options du compte", coche : **"Le compte est sensible et ne peut pas être délégué"**.

5. Clique sur OK et répète l'opération pour tes autres comptes d'administration.



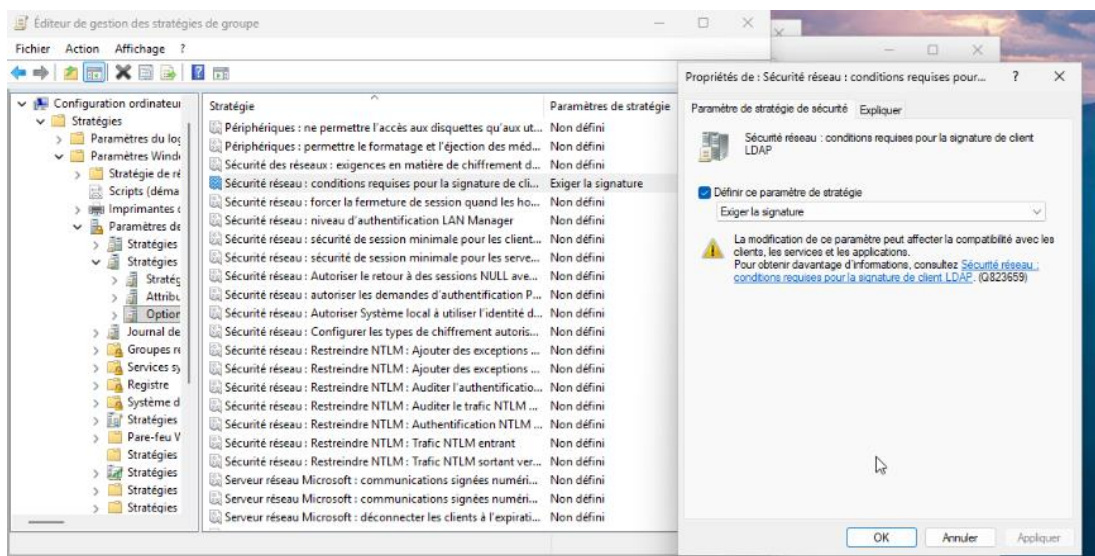
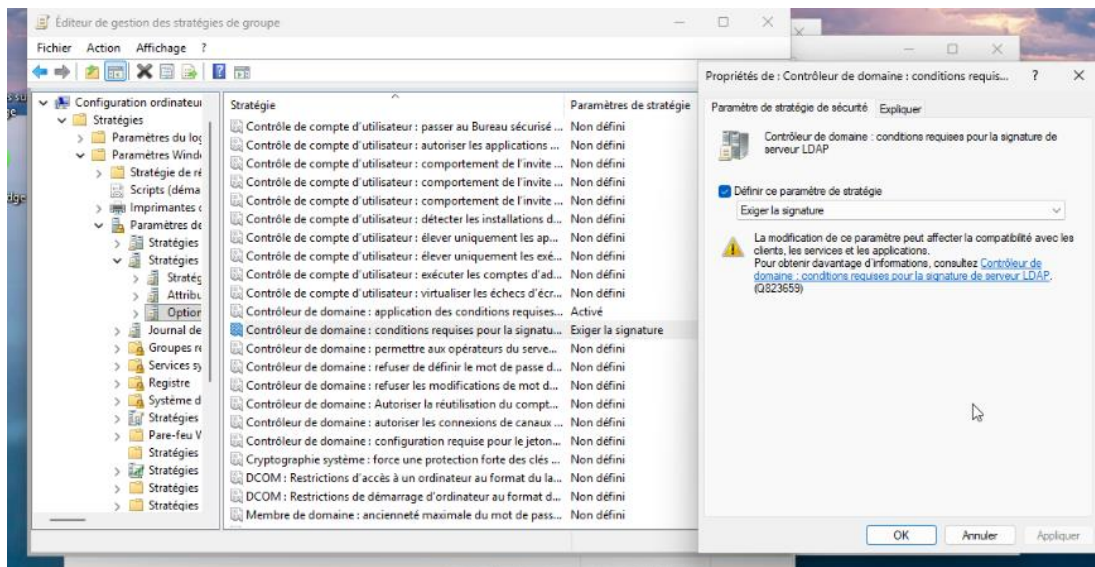
3. Activer la Corbeille AD (Test pour voir si ça a l'effet escompter)



4. Forcer les Signatures SMB et LDAP (Via GPO) gpmmc.msc

Pourquoi ? Bloquer les attaques de l'homme du milieu (MiTM).

6. **Chemin GPO** : Gestion des stratégies de groupe > Default Domain Controllers Policy > Modifier.
7. **Navigaton** : Configuration ordi > Stratégies > Paramètres Windows > Paramètres de sécurité > **Stratégies locales** > Options de sécurité.
8. **Réglages** :
 - *Contrôleur de domaine : exigences de signature de serveur LDAP -> Exiger la signature.*
 - *Sécurité réseau : exigences de signature de client LDAP -> Exiger la signature.*

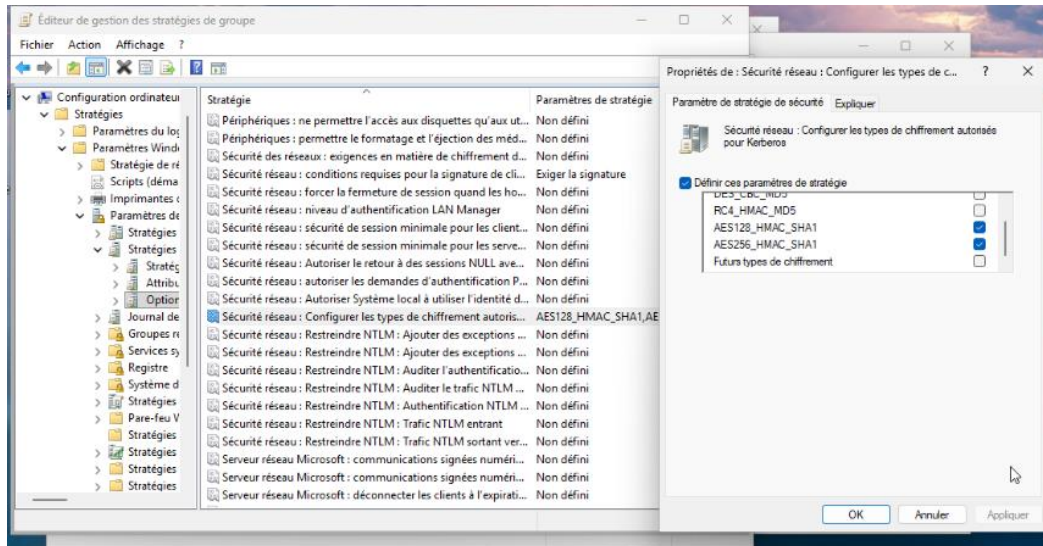


5. Restriction Kerberos & NTLM

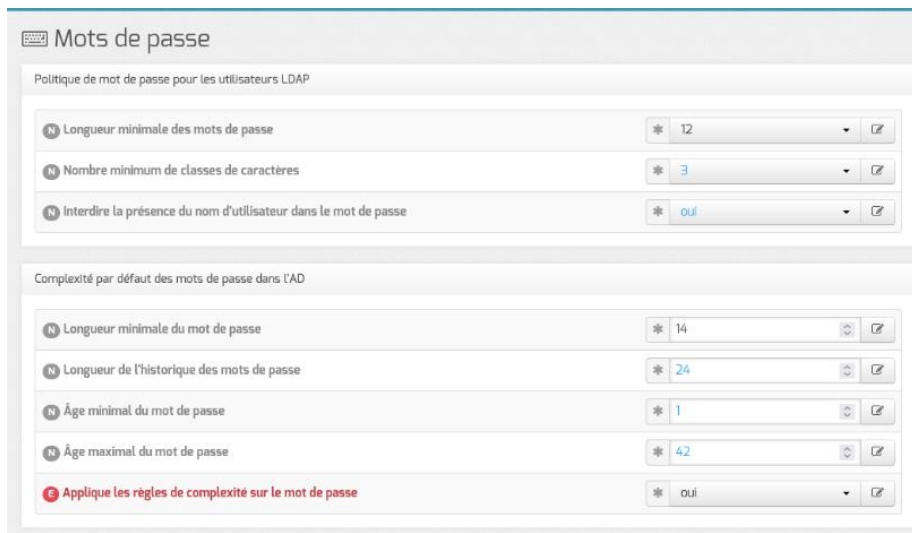
Pourquoi ? Supprimer les chiffrements faibles (RC4/DES).

- **Chemin** : Même dossier "Options de sécurité" que pour le LDAP.
- **Kerberos** : *Sécurité réseau : configurer les types de chiffrement autorisés pour Kerberos*
-> Cocher **uniquement** AES128, AES256 et Futurs types.
- **NTLM** : *Sécurité réseau : restreindre NTLM : authentification NTLM dans ce domaine* ->

Tout refuser (après audit).



6. Renforcement des mots de passe



Indicators



Domain Risk Level: 50 / 100

It is the maximum score of the 4 indicators and one score cannot be higher than 100. The lower the better

[Compare with statistics](#)

[Privacy notice](#)

Stale Object : 21 /100
It is about operations related to user or computer objects
8 rules matched

Trusts : 0 /100
It is about connections between two Active Directories
0 rules matched

Privileged Accounts : 50 /100
It is about administrators of the Active Directory
6 rules matched

Anomalies : 35 /100
It is about specific security control points
12 rules matched



ACTIVE DIRECTORY

Forest	scribe.local
No. of Domains	1
Duration	00:01:05
Run by	SCRIBE\Administr...

Indicators

Evaluated	113
Not selected	1
IOEs found	13
Passed	100
Failed to run	2
Not Relevant	3
Canceled	0

Pourquoi je n'ai pas pu atteindre un score supérieur à 91 % ?

Bien que les mesures de durcissement appliquées (LAPS, désactivation du RC4, signatures LDAP/SMB) aient considérablement renforcé la sécurité de l'annuaire, plusieurs facteurs techniques inhérents à l'architecture Samba 4 (Scribe) et aux contraintes du laboratoire limitent l'obtention d'un score de 100 % :

1. Blocage du niveau fonctionnel du domaine (2012 R2)

L'une des limites majeures rencontrées a été l'impossibilité technique de monter le niveau fonctionnel de la forêt et du domaine en Windows Server 2012 R2. Malgré l'utilisation de samba-tool et des consoles RSAT, l'instance Samba 4 a rejeté cette modification (erreurs de *Base DN* et exceptions Python). Ce blocage empêche l'activation du groupe de sécurité "Protected Users", une recommandation critique pour la protection contre le vol de hashes, et limite la résilience de la corbeille AD.

2. Les limites de l'émulation Samba 4

Samba 4 émule un contrôleur de domaine, mais ne supporte pas encore la totalité des fonctionnalités de sécurité modernes de Microsoft (comme les politiques de silos d'authentification ou les comptes de service gérés par le groupe gMSA). Les outils d'audit comme Purple Knight détectent ces absences comme des vulnérabilités, bien qu'elles soient structurellement impossibles à corriger sur un serveur Scribe.

3. Le risque de "Déni de Service" sur l'administration

Certains indicateurs exigent des restrictions extrêmement sévères sur le compte Administrator (notamment le flag *Sensitive*). Lors de la mise en œuvre, ces réglages ont provoqué des restrictions d'accès empêchant toute administration distante via les outils RSAT. Pour garantir la continuité de l'exploitation du serveur, un compromis a dû être trouvé entre sécurité maximale et maintenabilité du système : la sécurité ne doit pas empêcher l'administration.

4. Le reliquat d'objets "Stale" (Objets inactifs)

Le score dans la catégorie "Stale Objects" s'explique par la présence d'utilisateurs et d'ordinateurs de test créés pour le laboratoire. Dans un environnement de production, ces objets seraient supprimés, mais ils sont ici indispensables pour valider le bon déploiement des GPO et du durcissement Kerberos.

Pourquoi les restrictions Kerberos & NTLM (AES128, AES256 et Futurs types) empêchent la connexion à mon poste ?

Est-ce impossible de forcer les Signatures SMB et LDAP (Via GPO) ?